ソフトウェアサプライチェーンにおける不正機能検出実務の調査と分析

藤井 翔太[1,a)]　田井 光春[1]　塙 剛生[1]　平島 陽子[1]　山崎 裕紀[1]　安藤 英里子[1]

概要：欧州サイバーレジリエンス法（CRA）に代表される近年の各種規制により，ソフトウェアサプライチェーンにおける不正機能を検出し，その影響を軽減することが求められている．他方で，不正機能検出に係る実態，役割分担，および支援要件は十分に整理されているとは言えない状況である．そこで本研究では，日本企業の設計者，開発者，運用者，ツールベンダ，およびセキュリティサービス提供者 17 名への半構造化インタビューにより，その実態，課題，および支援要件に係る調査と分析を実施した．分析の結果，不正機能検出は設計・開発・検証・運用等の各段階に分散し，日常的な開発・検証・運用の中で行う検査・確認と，必要や要求に応じた詳細調査の 2 つに大別できることが明らかとなった．課題としては，検出性能の限界に加えて，判断に必要な情報の不足，検出対象や悪意性の曖昧さ，および組織・役割間の連携上の制約があることを示した．さらに，実務的な支援には，検出性能だけでなく，組織や利用状況に応じて判断・運用・情報共有を支える仕組みが必要であることを整理した．最後に，上記の結果を踏まえた研究開発ならびに実務上の提言事項を示した．

キーワード：ソフトウェアサプライチェーン，不正機能検出，セキュリティ実務，質的研究

Practices and Challenges of Malicious Functionality Detection in Software Supply Chains

Shota Fujii[1,a)]　Mitsuharu Tai[1]　Goki Hanawa[1]　Yoko Hirashima[1]　Hiroki Yamazaki[1]
Eriko Ando[1]

Abstract: Recent regulations, including the EU Cyber Resilience Act (CRA), require organizations to detect and mitigate malicious functionality in software supply chains, yet practical processes, role allocation, and support needs remain unclear. We interviewed 17 practitioners from Japanese companies, including designers, developers, operators, tool vendors, and security service providers. Detection was distributed across the software lifecycle, combining routine checks in development, validation, and operations with additional investigation when needed. Key challenges included limited detection performance, insufficient information for judgment, ambiguity over targets and maliciousness, and coordination across roles and organizations. Effective support therefore requires mechanisms for decision-making, operations, and information sharing, not detection alone. We conclude with recommendations for research, development, and practice.

Keywords: software supply chain, malicious functionality detection, security practice, qualitative study

1. はじめに

現代のソフトウェア開発は，単一組織の内部だけに閉じるものではなく，外部への委託開発を含む [1]．また，OSS ライブラリ，クラウド API，外部 CI/CD サービス等の多様な外部コンポーネントやサービスに依存している [2–4]．このため，ソフトウェアセキュリティは，個別製品だけでなく，ソフトウェアサプライチェーン全体の安全性に依存する．実際に，ソフトウェアサプライチェーンに対しては，依存関係や更新経路等を悪用した多様な攻撃が報告されて

[1] 株式会社 日立製作所，Hitachi, Ltd.
[a)] shota.fujii.xh@hitachi.com

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

おり [5,6]，バックドア，不審な外部通信，悪性パッケージ，仕様外コード等の不正機能が正規のソフトウェアや依存関係に紛れて導入される可能性がある [4,7]．こうした状況において，欧州 Cyber Resilience Act（CRA）[8] や米国 Executive Order 14028 [9] に代表される近年の規制では，ソフトウェアサプライチェーンを含めたセキュリティリスクへの対応が求められている．

一方で，不正機能の検出は，単にソフトウェアを解析して疑わしい箇所を発見するだけでは完結しない．検出された候補について，仕様，設計意図，実行時挙動，通信，ログ，利用環境等の情報を踏まえて対応要否を判断し，必要に応じて修正や関係者への説明につなげる必要がある．その過程には，複数の役割が関与し得る．しかし，実務において，何を不正機能として扱い，誰が，どの工程で，どういった情報を用いて検出結果を判断するかは，依然として十分に整理されているとは言えない状況である．

こうした背景から，本研究では，サプライチェーンセキュリティ（以降，SCS）の文脈での不正機能検出に係る実態解明と，今後の改善を見据えた課題や支援要件の導出を図る．具体的な研究課題（以降 RQ）は以下の通りである．

RQ1. 不正機能検出は，どの役割によって，どのように行われるか（**実態**）．

RQ2. 不正機能検出を妨げる課題は何か（**課題**）．

RQ3. 不正機能検出の実践的な支援には何が必要か（**要件**）．

これらの RQs を解明するため，設計者，開発者，運用者，ツールベンダ，およびセキュリティサービス提供者 17 名を対象に半構造化インタビューを実施すると共に，Grounded Theory [10] ベースのアプローチでの分析を行った．

本研究における主たる貢献は以下の通りである：

- 複数の役割に跨った実務者 17 名へのインタビューを通して，不正機能検出に係る実態を明らかにした．
- また，現状の不正機能検出における課題や実践的な支援に必要な要件を整理した．
- さらに，インタビュー結果を基に，実務者と研究者の両面から提言事項をまとめた．

2. 関連研究

サプライチェーンセキュリティ（SCS）. SCS 分野においては，エコシステム測定 [11]，攻撃の分類・体系化 [5]，来歴の保証メカニズム [3] 等，様々な研究が行われている．また，実証的アプローチによって実態や課題も調査されている [2,12,13]．Sammak ら [13] は，開発者にインタビューを行い，一般的なセキュア開発は整備が進んでいる一方で，サプライチェーン固有の脅威に対する認識や対策は限定的であることを示した．Williams ら [12] は，実務者調査により，サプライチェーン攻撃の急増や各種規制が組織内でのタスク採用にどのような影響を与えているかを示した．

これらに代表される SCS の研究は，SCS に係る脅威，緩和策，課題に関する技術的手法や知見を提供しているが，不正機能検出がどのように実施され，役割や段階によって責任や証拠要件がどう異なるかは明らかにしていない．これに対し本研究では，不正機能検出をステークホルダー全体の視点から捉え，検出の実施主体，対象，検証上の障壁，必要な支援要件を実証的に整理する．

不正機能検出. 不正機能検出については，技術的な研究が複数実施されている [4,7,14,15]．Ganz らの手法 [14] は，リポジトリのコミット履歴をモデル化し，グラフニューラルネットワークベースの異常検出によりバックドア挿入を識別している．ROSA [15] は，ファジングの応用によってバックドアの識別を達成している．DeepReflect [7] は，オートエンコーダを用いてバイナリ内の悪性挙動領域を局所化することで分析者のリバースエンジニアリング作業を省力化する．

これらに代表される不正機能検出の研究は，不正機能の発見，誘発，局所化等の検出技術を確立・発展させている．これに対し本研究では，検出技術そのものではなく不正機能検出に係る実務に焦点を当て，その実態の導出を図ると共に，課題や支援要件を整理する．

3. 調査方法

3.1 不正機能の定義と範囲

本研究では，ソフトウェアサプライチェーンにおける不正機能検出を取り扱う．他方で，先行研究では「不正機能」や「malicious functionality」に相当する概念が文脈により異なる粒度や観点で議論されている．

例えば，NIST SP 800-161 [16] は，サプライチェーン攻撃において，攻撃者が機能を意図的に挿入・改変することで不要な機能が生じると説明している．文献 [7] 等の不正機能検出の研究でも，攻撃者の意図・目的に沿った機能や振る舞いを検出対象とすることが多い．一方で，文献 [17,18] に代表されるような，意図的なものに限らず不要な機能やコードを無効化・削除することによって脆弱性や攻撃対象領域を低減する研究も行われている．

このように，「不正機能」や関連する概念が指す範囲は文脈によって異なり，参加者間で解釈が一致しない可能性が考えられる．そこで本研究では，意図的か否かを主な区別軸として不正機能を次の 2 種類に整理し，インタビュー前に参加者へ提示することで，認識のすり合わせを実施した．

- **広義の不正機能：**意図の有無によらず，悪性挙動や重大なリスクにつながり得る機能（既知の脆弱性や削除し忘れたデバッグ機能等を含む）．
- **狭義の不正機能：**機密データの外部送信やバックドア等，悪性挙動のために意図的に埋め込まれた機能．

© 2026 Information Processing Society of Japan

表 1 インタビュー参加者

ID	時間 [1]	経験年数		役割 [2]	狭義の不正機能 [3]
		現職	セキュリティ		
P1	0:49:15	2	4.5	SP	○
P2	1:18:26	14	20	TV, SP	●
P3	0:53:08	6	10	SP	○
P4	0:55:37	3	3	TV	○
P5	0:58:27	7	7	DES, DEV, TV	○
P6	1:20:32	5	5	DES, DEV, OPE, TV, SP	○
P7	1:05:32	1	5	TV, SP	○
P8	0:53:48	3	3	TV, SP	○
P9	1:09:28	10	20	DEV, TV	○
P10	1:36:22	21	21	DES, DEV, OPE, TV, SP	●
P11	0:59:38	5	8	OPE	●
P12	0:49:14	13	13	DES, DEV, OPE, SP	●
P13	1:06:34	3	3	SP	●
P14	1:22:07	6	6	DES, DEV, TV, SP	●
P15	1:09:57	4	4	TV	●
P16	0:24:09	1	1	TV, SP	●
P17	0:23:04	10	10	TV, SP	●

[1] P16 と P17 は，参加者の希望により説明を含めて 30 分以内で実施.
[2] DES：設計，DEV：開発，OPE：運用，TV：ツールベンダ，SP：サービス提供.
[3] 明示的に調査対象として含む（●），明示的ではないが検出範囲に含まれている（○）.

3.2 参加者募集

参加者募集に先駆けて DevSecOps と SCS の研究者 2 名と議論し，不正機能検出に係る実態を整理すると共に，関連する 5 つの役割を以下の通り特定・定義した.

- **設計者・開発者：** ソフトウェアの設計および実装に関与し，開発中に不正機能を予防・検出する責任を含む.
- **運用者：** セキュリティ関連タスクを含め，製品の管理および運用を担当する（例：QA や PSIRT）.
- **ツールベンダ：** 不正機能検出を支援するツールを提供する（例：EDR や SCA ツール等のベンダ）.
- **サービス提供者：** 不正機能検出を含むセキュリティサービスを提供する（例：MSS や SaaS 型ツール提供）.

SCS の文脈で上記の役割を 1 つ以上有する参加者を専門的ネットワークと紹介により募集し，研究目的，対象者，内容，所要時間，データ取扱いを説明した．その後，同意を得られた参加者に対してインタビューを実施した．最終的に，**表 1** に示す 17 名の協力を得ることができた．また，先行研究 [13, 19] 等と同様に，金銭的謝礼は提供せず，参加協力への還元として研究結果を共有することとした．なお，参加者は全て日本企業に所属する日本語話者であった.

3.3 インタビューの設計と手順

インタビュー時の質問は RQ に対応する形で著者らが設計した後，DevSecOps・SCS 研究者 2 名による 1 回目，サイバーセキュリティ研究者 5 名による 2 回目のレビューを通して改善を図った．最終的に，参加者の役割に応じた 12 または 13 問の構成とした．全文は，付録 A.2 節に示す.

各インタビューは，背景等の説明から開始した．次に，参加者の経歴や所属組織に関する質問を実施した．続いて，不正機能検出がどのような実態で実施されるか，その中でどのようなツールやサービスが使われているかを質問した（RQ1）．その後，課題について質問し，関連する作業や狭義の不正機能に特有の課題を掘り下げた（RQ2）．また，不正機能検出における実態やツールに関する支援要件を尋ねた（RQ3）．最後に，追加のコメントや質問を確認し，録音を終了してクロージングを行った.

インタビューは，2025 年 4 月から 2026 年 6 月に Microsoft Teams[*1]で録音しながら実施し，平均時間は 1 時間 54 秒であった．多くのインタビューは第一著者が主導し，第二著者が進行を補助した．なお，最初の 2 件はパイロットスタディとして実施したが，実質的な変更がなく，得られたデータが後続インタビューと同等に分析可能であったため，これらも最終データセットに含めた.

3.4 質的分析

プライバシー保護のため，文献 [20] 等の先行研究に倣い，録音したインタビューはローカル環境で動作する音声認識ツール Whisper[*2]で文字起こしを行い，適宜人手で修正した．文字起こしデータは，Grounded Theory [10] ベースのアプローチ，具体的には open coding，axial coding，selective coding の 3 段階で分析した．第一段階の open coding では，第一著者が最初の 5 名の参加者の録音と文字起こしに基づいて初期コードブックを作成した．この初期コードを基に第一著者と第三著者が独立してコーディングし，逐次的に改訂版コードブックを作成した．コーディング中に曖昧さや新しいコードが生じた場合には，2 名で協議してコードブックを反復的に更新した．その後，axial coding で関連コードをカテゴリ化し，selective coding でカテゴリ間の関係を統合して主要テーマを抽出した．この際にも，2 名の著者で協議を行い，意見の相違を解決した．このため，本分野の質的研究における慣行 [21] に従い，評定者間信頼性の数値は割愛する．また，参加者レビューを実施し，解釈の誤り，匿名化の不十分さ，公開を望まない内容等がないかを確認した．この過程で，4 件の修正と 1 件のオプトアウトを反映し，最終的なコードブックとした.

3.5 制限事項

本研究には，インタビューに基づく研究に共通する限界がある．これには，過大報告や過少報告の可能性，自己申告バイアス，想起バイアス，社会的望ましさバイアス，サンプリングバイアス，一般化可能性の限定性が含まれ得る [22]．さらに，参加者は関連するすべてのステークホルダーを完全に代表しているとは限らないが，募集基準を満たす多様な専門家にインタビューすることで，これらのバイアスを緩和することを目指した．ただし，本研究は 17 名への質的インタビューに基づく探索的研究であり，統計的代表性を主張するものではない．このため，知見の一般

[*1] https://www.microsoft.com/en-us/microsoft-teams/group-chat-software/
[*2] https://github.com/openai/whisper

© 2026 Information Processing Society of Japan

化には，更なる定量的研究による調査が必要である．

4. 結果

本章では，17 名へのインタビューとその分析から得た主要なテーマを RQ 毎に示す．各テーマの頻度については，文献 [23] 等の先行研究に倣い，本分野で確立された次の表現を用いる：なし（0%），ごく少数（1–20%），一部（21–40%），約半数（41–60%），大多数（61–80%），ほぼ全員（81–99%），全員（100%）．ただし，本分析・知見は定性的なものであり，定量的な代表性を示すものではない．

4.1 RQ1：実態

4.1.1 不正機能検出の形態

不正機能検出の形態は一様ではなく，大きく 2 つのアプローチが見られた．第一のアプローチは，既存の脆弱性管理やセキュア開発プロセスに組み込まれた自動的な検出である．この形態では，CI/CD 等の自動プロセスの中で，主に広義の不正機能（既知脆弱性，危険な API 利用，弱い暗号方式，アクセス制御の誤り，EOL コンポーネント等）が検出対象として扱われていた．また，一部の参加者は，意図の有無は意識せずに，不正機能となり得るものはすべて検出すると述べた：“意図的かどうかに依らず，不正機能に見えるものを検出することを目指している”（P3）．

第二のアプローチは，バックドア，隠しアカウント，仕様書外のコード，不審な外部通信といった狭義の不正機能を明示的に対象とする調査型の検出であった．この形態では，コード上の特徴だけでなく，実行時挙動，通信，ログ，仕様，運用環境を突き合わせて，意図的な混入の可能性を判断していた．一部の参加者は，こうした違いから，広義と狭義は別の視点で検査する必要性を述べた：“従来の脆弱性等は種類や探し方がイメージしやすく整理もされている．一方で，狭義の不正機能は，敢えて見つけにくくするなど，人為的ミスとは別の次元で埋め込まれる．[...] 脆弱性とは全く違う視点で調べないといけない”（P2）．

ただし，両者は常に分離されるわけではなく，一部の参加者は，不正機能検出基盤を通常の脆弱性検査に組み込んでいた：“論文を参考にバックドアや仕様外コードを自動検出する仕組みを実装し，脆弱性と同時に狭義の不正機能を確認している”（P10）．

4.1.2 不正機能検出に係る役割・工程別の実施事項

不正機能検出は，特定の役割のみが担う活動ではなかった．例えば，開発部門は依存関係管理，検出，修正等を，PSIRT はトリアージ，リスク評価，対応管理等を，QA や第三者サービスは出荷前検証，証跡作成，顧客説明等を担っていた．それに付随して，不正機能検出は，設計，開発，出荷前検証，運用，検出後対応の各工程に分散していた．設計段階では，脅威モデリング，設計レビュー，シミュレータを用いた異常入力処理の検証が行われ，後工程で不正機能や脆弱性として顕在化し得る可能性の低減が図られていた．これについて，P13 は “我々は Shift Left を推進している．[...] 脅威モデリングやセキュリティバイデフォルトに取り組んでいる” と述べた．

開発段階では，大多数が OSS コンポーネントの脆弱性管理，SCA，SAST，リンター，コーディング規約違反の検出，チェックリスト確認などを実施していた．P13 は，実務で継続させるには開発者の通常ワークフローへ組み込む必要があると述べた．また，前述の通り一部の参加者は，狭義の不正機能の検出についても自動化を試みていた．

出荷前・第三者検証では，ソース・バイナリ解析，SBOM・既知脆弱性照合，ペネトレーションテスト，ファジング，不審通信確認等が組み合わされていた．運用段階でも，セキュリティ監視，EOL ソフトウェアの検出，依存ライブラリ更新時の不審な変更確認，ログ・通信の監視が継続されていた．検出後，PSIRT が開発チームへ修正を依頼するだけでなく，修正方針や修正結果の妥当性について連携するプロセスも見られた：“PSIRT は修正依頼だけでなく，修正方針や結果についても開発チームと連携している”（P11）．

4.1.3 多層的な検出手法とツールの組合せ

不正機能検出は，単一手法・ツールではなく，複数の手法やツールの組み合わせによって多層的に実施されていた．静的解析では，ソースコードやバイナリに対して，既知脆弱性に紐づくパターン，危険な API 利用，ハードコードされた機密情報，不要なサービス，仕様外の実装等を抽出していた．これについて，P2 は，“検査対象をディスアセンブラに入れて機能を 1 個 1 個検査していく” と説明した．

動的解析では，ファジング，ペネトレーションテスト，脆弱性への到達性検証，サンドボックス実行等が用いられていた．一部の参加者は，対象の応答を見ながらファジング内容を変えるような適応的な検証も実施していた：“静的解析では問題なさそうでも，動的実行で問題が出ることがある．メモリ領域が動的に参照される場合に問題が起こり，そこに不正機能が埋め込まれる可能性がある”（P8）．

SCA/SBOM と脆弱性データベース照合も中心的な手法であり，大多数がソフトウェアに含まれるコンポーネントを特定し，既知脆弱性や悪性パッケージ情報と照合する手法に言及していた：“SCA ツールで SBOM を生成し，既知脆弱性のデータベースと突き合わせる”（P14）．

また，商用・OSS ツールで不足する部分は独自実装で補われることもあった：“OSS や市販ツールを組み合わせつつ，足りない機能に関しては自分たちで実装して組み合わせている”（P14）．さらに，約半数はライブラリ更新時の検証やツール出力の対応優先度付け等，様々な場面で AI や LLM を活用していた：“開発しているソフトウェアの依存ライブラリを更新する際，Claude を使って不審なものが含まれていないか確認している”（P17）．

© 2026 Information Processing Society of Japan

4.1.4 検証の実施要因

P9 は，実施主体や顧客ごとに不正機能検出の実施要因が異なることを述べた：“不正機能検出の動機は役割や責務に応じて異なる．例えば，顧客へのエビデンス提出の場合もあれば，リスク管理を強化するために行う企業もある”．

検証，特に第三者検証の実施要因も多様であり，政府からの依頼，法令・規制対応，納品時の検証，バックドア検出に関する報道に係る経営層からの依頼等が挙げられた．一部の参加者は，日本国内の顧客であっても，製品の海外展開等のために，CRA のような海外の規制への対応も実施要因であると述べた：“検査依頼の契機としては法令対応が圧倒的に多い．ここ数年は医療機器の JIS T 81001-5-1 への対応，直近では CRA 対応がほとんどであった”（P7）．また，P2 は，報道や経営層の懸念が検証依頼につながることを説明した：“類似の製品でバックドアが見つかったという報道があると，[...] 経営側が気にして依頼が来る”．このように，不正機能検出はリスク低減・被害抑制だけでなく，説明責任や規制対応としての側面も見られた．

> **RQ1 に係るまとめ**
> 不正機能検出の形態は，脆弱性管理やセキュア開発プロセスに組み込まれた自動的な検出と狭義の不正機能を対象とする調査型の検出の 2 つに大別できた．不正機能検出は複数の役割に分散し，各役割で複数の手法・ツールを組み合わせて実施されていた．また，不正機能検出には，リスク低減や被害抑制に加えて，説明責任や規制対応としての側面も見られた．

4.2 RQ2：課題

4.2.1 検出対象や判断基準の不確実性

約半数の参加者が，不正機能として何を検出すべきかが明確でないことを課題として挙げた．一般的な脆弱性検証では CVE，CWE，既知の脆弱性パターン等を参照できる一方で，狭義の不正機能にはバックドア，不審通信，仕様書外コード，悪性パッケージ等が含まれ得るものの，共通的な定義や検出方法は十分に確立されていない．“脆弱性などはある程度一般の定義や共通認識があるが，不正機能は人によって解釈が違うと感じる”（P8）．

また，コード上の危険性と意図性の有無の区別が難しい点も挙げられた．例えば，アクセス制御の未実施が見つかっても，意図的な不正機能か実装ミスかをソースコードだけで判断できない場合がある：“コード上の危険性だけでは悪意か実装ミスか判断できない”（P12）．さらに，大量調達や重要顧客案件では，不正機能として起票・修正するには強い根拠が必要であり，検出結果の検証や社内外の調整も負荷となっていた：“不正機能候補が見つかった際，その真正性が問題となる場面がある．[...] 例えば既に大量に調達した機器であった場合，実際に修正するとなると金銭的なコストが発生するため確かな証拠が必要になる”（P15）．

4.2.2 検出精度と解析上の技術的限界

共通的な課題として，検出技術の精度限界と，それに伴う確認作業の増加が挙げられた．これについて，P4 は“100%の精度は現実的でなく，見逃しや誤検出が発生するため，最終的な精査は別途実施する必要がある” と言及した．特に狭義の不正機能では，ツールの検出結果だけで確定的に判断できず，追加調査を要する点も課題であった．こうした技術的限界から，一部の参加者は完全自動判定よりも調査支援が現実的かつ有用だと述べた：“検出結果に対して，何をどのように調査して検証すればよいかを表示するのが望ましい”（P3）．

4.2.3 規模，環境，データ品質，統合に伴う運用上の制約

実務における検出は，対象システムの規模や複雑さに左右されていた．大規模ソフトウェアでは静的解析に日単位の時間を要する場合があり，ファジングでも大量のログ確認が必要となるため，開発プロセスへの組込みや自動化が難しくなる点が挙がった：“特に大規模なものを検証する場合，[...] 場合によっては日単位で時間がかかるので，CI の中で毎回検証するのは現実的でないことがある”（P5）．

検証環境や対象固有の条件も実務上の制約となっていた．IoT 機器や制御系システムでは，外付けハードウェアや本番同等の環境を用意できない場合があり，バイナリのみの納品，独自プロトコル，非公開仕様，言語・アーキテクチャの違いも汎用ツールによる検証を難しくしていた．P7 は，“ハードウェアによって処理性能が変わるため，異なるハードウェア上で動作するシステムや機能に関して本番環境とテスト環境で同じテストができているか不明瞭である場合がある” と述べた．

データ品質や関連エコシステムの制限も検出作業を難しくしていた．納品時の SBOM 未提供，ツールの SBOM 生成精度の低さ，名称・バージョンの表記ゆれ，暗黙的パッチ，脆弱性データベースの分散等により，SBOM と脆弱性情報を正確に照合できない場合があった：“SBOM があっても名前やバージョンの揺れがあるので，脆弱性データベースときれいに突合できるとは限らない”（P3），“SCA ツールには，ツールごとの出力の差がある”（P11）．

4.2.4 組織，ビジネス，規制，市場成熟度に起因する制約

技術的限界に加え，非専門家によるツール出力の解釈，人材不足，予算・契約，市場の成熟度も課題となっていた．特に，専門家による確認を経ずに結果が利用されることで，適切な検証や対応につながらない懸念があった：“必ずしも専門家が出力結果を確認する訳ではないため，結果の検証ができないケースや開発元に修正を丸投げするというケースが発生し得る”（P8）．一部の参加者は，規制強化や AI コーディングの普及により，こうした問題がさらに顕在化する可能性を指摘した．

予算，スケジュール，契約範囲も，実務上の検証範囲や終

© 2026 Information Processing Society of Japan

了条件を左右していた．P6 は，“スケジュールや予算の関係で検証できない範囲が生じる場合がある” と述べた．制御系や重要インフラでは，システムへの負荷を懸念して検査自体が避けられ，見逃しにつながる可能性も挙げられた．

法令や市場の成熟度は検証導入を促す要因となる一方，実施範囲の判断を難しくしていた．CRA，医療・金融分野の規制，JIS T 81001-5-1 等への対応が検証依頼を促す一方，要求の曖昧さも課題となっていた：“法規やガイドラインの定義が曖昧な部分があり，具体的に何をどこまで対応して良いか不明瞭である”（P14）．さらに，検出件数を KPI として過度に重視すると，検出活動が本来のリスク低減から乖離する懸念も示された：“ツールでの検出数をゼロにする，或いは何件以上検出されるまでテストする等，開発のセキュリティに係る KPI がツールに依存しすぎており，本質的ではないという課題を感じている”（P5）．

> **RQ2 に係るまとめ**
> 「不正機能」に係る定義の曖昧さに起因する判断の難しさや認識合わせの難しさがある．また，各種ツールの精度や検証環境構築の難しさ等の技術的な課題に加え，人材・予算の制約や規制対応の難しさ等の技術面以外での課題も挙げられた．

4.3 RQ3：要件

4.3.1 検出対象と検出性能

参加者は，まず検出対象を明確に定義することを求めていた．特に狭義の不正機能では，何を不正機能として扱うかが曖昧なままでは，検出結果の解釈や終了条件が定まらない．P12 は，検出対象の明確化が不正機能検出の前提になると述べた：“不正機能の定義にばらつきがあり，[...] まず検出範囲について合意を取る必要がある．そうでなければ，これを見つけてくれると思っていたという話になる”．

また，検出能力には，複数言語，複数アーキテクチャ，独自コンパイルルール，独自プロトコル，およびソースコードだけでなくバイナリやファームウェアに対応できること等，幅広い対応可能性が求められた．特に IoT 機器や制御系では，独自プロトコルやハードウェア条件が存在する傾向にあるため，検査内容やペイロードをカスタマイズできることが重要とされた．

検出精度については，高精度化だけでなく，パラメータによる過検出と見逃しのバランス調整可能性や動的解析の再現性が重視された．P4 は，“製品や顧客に応じて検出強度を調整できることが望ましい” と説明した．

4.3.2 説明可能性，証拠提示，意思決定支援

不正機能検出においては，単なる候補の検出ではなく，各役割の担当者や顧客が判断，修正，説明に使える証拠や根拠が必要であり，約半数の参加者がこの説明可能性に言及した．具体的には，出力には，検出理由，ロジック，周辺情報，影響範囲，再現手順，対応案等を含めるべきだとされた：“不正機能が検出された場合，結果とともに理由や検出ロジックを示すことが望ましい”（P15）．また，同じ候補でも，開発者には修正箇所と再現条件，運用者には影響と優先度，顧客には自環境での発現条件，経営層には対応状況と残余リスクが必要であり，役割に応じた出力が可能であることが望まれた．

また，約半数の参加者が優先度付けを求めた．参加者は，対応に係る時間的・人的リソースの制限から，KEV，EPSS，到達性，実利用状況，顧客環境，被害規模などの様々な要因を踏まえ，対応優先度を示すことを求めていた：“狭義の不正機能や脆弱性がある場合，流行している，狙われている，悪用された際のリスクが自社に大きい，といった理由で優先度を判断する機能が欲しい”（P17）．

UI 面では，PDF レポートだけでは検査対象と突き合わせる負荷が大きいため，一覧表示，可視化，ソースコード上のハイライト，周辺情報の提示，解析進捗表示等が求められた．出力形式についても，CSV 等の加工しやすい形式や VEX 等の脆弱性開示・共有プロセスで利用できる形式が望まれていた．また，日本語での出力や顧客や経営層への説明を考慮した非専門家向けの平易な説明も求められていた．“非専門家は不正機能の詳細を解説されても困るので，優先順位，対応方法，リスクなどを役割に応じて分かり易く解説するのが良いと思う”（P17）．

4.3.3 継続的検証，自動化，ワークフロー統合

約半数は年次・出荷時のみの検査では不十分とし，CI/CD パイプライン等に組み込み，コミット，マージ，依存関係更新，新規脆弱性発見，運用時の異常等を契機に継続的に検査を実行できる必要があると述べた：“年 1 回の検査では間隔が長すぎる．[...] 不正機能検出をどのように自動で高頻度に実行するかが課題だと感じている”（P17）．自動化による工数削減や属人性低減に関連して，約半数の参加者は，検出後の分析，対応案提示，調査手順提示，チケット起票，過去対応履歴の反映まで支援することを求めていた．

既存ツールや業務システムとの連携も重要であり，静的解析と動的解析の一気通貫実行，複数ツール結果のダッシュボード表示，アセット DB・チケット管理・ナレッジベース・Web API との接続等が挙げられた．ただし，すべての参加者が連携を最優先したわけではなく，実際に自動ツールのみでは達成が困難な不正機能検出を独立した手動の専門的プロセスとして実施している組織もある．このため，必要な接続を段階的に追加できる拡張性が重要である．

4.3.4 導入形態，データ保護，サービス運用

SaaS は導入や更新が容易な一方で，ソースコード，ビルド環境，ハードウェア構成，顧客ログ等の機密性が高い情報のクラウドへのアップロードに懸念がある点が挙げられた：“機密性の高い情報をクラウドに上げることにはリスクがある．また，実際にはリスクが低くても，OT や重要

© 2026 Information Processing Society of Japan

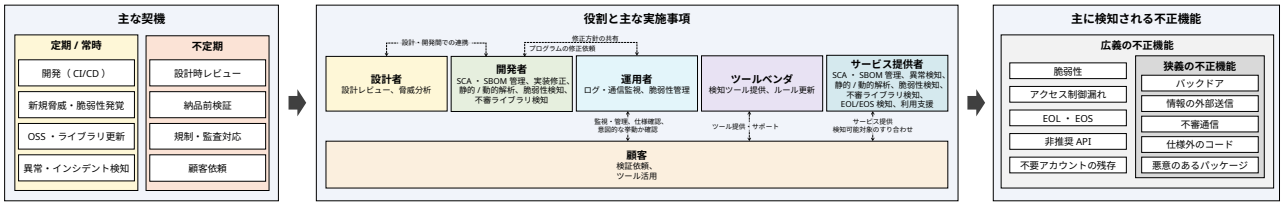


図 1　インタビュー結果に基づくサプライチェーンでの不正機能検出実務の全体像

インフラの顧客はオンプレミスを好むことが多い”（P10）．一方で，オンプレミスでの提供には，スケール，更新，ツールベンダ側の知財保護という課題もある．以上のトレードオフから，大多数の参加者がオンプレとクラウドの両方の提供形態を兼ね備えることが望ましいと述べた．

4.3.5　知識更新と規制対応

不正機能検出支援には，検出時点の静的なルールだけでなく，継続的に更新されるナレッジベースが重要である．“ナレッジベースは日々更新されていくことが必要である．[...] 昨日までは不正機能でなかったものが今日は不正という場合もある”（P8）．ナレッジベースの内容としては，脆弱性情報，狭義の不正機能情報，暗黙的パッチ情報等が挙げられた．各種規制の変化に追従するために，レポート形式や証跡の出し方を柔軟に追加できることも求められた．

> **RQ3 に係るまとめ**
> 不正機能検出の実践的支援には，検出性能だけでなく，検出された候補が不正機能か否かの判断支援に係る説明可能性や対応優先度付けが重要である．また，規制対応や利用者層の拡大を踏まえ，非専門家や経営層を含む，利用者や説明対象の役割に応じた出力の粒度・詳細度の調整も重要な要件として挙げられた．

5.　議論

5.1　考察

役割に応じた検出実務と連携．インタビューで確認された不正機能検出の契機，役割，実施事項，および検出対象を横断的に整理した全体像を**図 1** に示す．前述の通り，不正機能検出は，役割毎に異なる契機や実施事項の下で実施されていた．その上で，対象や検出結果に応じて，他の役割や組織と連携して追加の確認や対応を行う場合も見られた．このため，不正機能検出支援では，各役割における活動を支援するとともに，必要に応じて役割・組織間で情報や検出結果を共有・引き継げることも重要だと考えられる．

判断に必要な文脈の分散．狭義の不正機能は，コード上の危険性のみから意図的な挿入か実装ミスかを判別できず，仕様，設計意図，ログ等を組み合わせる必要があった．一方，これらの情報は，場合によっては複数の役割や組織に分散し，契約や機密性も取得・共有できる範囲を制約していた．静的解析や SOC の実務では，文脈不足が結果の解釈や対応を難しくすることが報告されている [19, 24]．本研究でも，不正機能検出において文脈不足が課題となることが確認され，特に，仕様内の機能，偶発的な欠陥，意図的な挿入を区別するために，複数の役割に分散した文脈を補完する必要性が示唆された．

説明可能性と役割別出力．参加者が要件として挙げた説明可能性は，検出理由，検出箇所，検出ロジック，影響範囲，再現手順等を検出結果と結び付け，候補が不正機能に該当するかの判断と対応の優先度付けを支援するものであった．また，同じ検出結果でも，開発者には修正箇所，運用者には影響や対応優先度，顧客には自環境での発現条件，経営層には対応状況やリスク，といった形で，別々の情報が追加説明として求められる．さらに，CRA 等への対応によって利用者や説明対象が広がるほど，対象の役割に応じて出力の粒度・詳細度を変更できることが重要になると推察される．

運用・導入形態の柔軟性．不正機能検出に際して，CI/CD や運用監視への組込みと自動・継続的検出が広く求められた一方で，狭義の不正機能調査に関しては，対象固有の仕様・環境を踏まえた人手の検証も重要な役割を有していた．このため，完全自動化や一律の統合を前提とせず，人手での検証も考慮した候補抽出，関連情報提示，優先度付け等を段階的に支援する設計が望ましい．また，ソースコードや顧客ログ等の機密性を踏まえ，クラウド，オンプレミス，または両者を組み合わせた導入形態を選択できることも重要である．これらは，不正機能検出の支援を単一の運用・導入形態に固定せず，組織や対象の条件に応じて選択・併用できる柔軟性が重要なことを示唆するものと考えられる．

5.2　提言事項

以下の内容は，本研究で得られた探索的知見に基づくため全ての SCS 環境に一様に当てはまるとは限らないが，今後の研究・ツール設計・実務改善を検討する上での参考になるものと推察される．

5.2.1　研究者への提言

不正機能検出技術に係る評価には，その実態を踏まえ，検出精度に加えて，処理時間，検出根拠の十分性や再現性，役割別の出力の理解しやすさ等を含めることが有用である．また，保守用アカウントやデバッグ機能の残存，サードパーティへの外部通信等は，文脈や意図性に依って狭義の不正機能か否かが変わる．このため，特に狭義の不正機

© 2026 Information Processing Society of Japan

能の検出技術には，不審な機能そのものを検出する機構に加えて，仕様からの逸脱性の判定や意図性の推察による判断支援を行う機構の研究開発も重要であると推察される．

さらに，実務のプロセスに沿ったユーザブルなツール設計を重視することが有用である．Kaur らが脅威モデリング支援について，実務への適合性を論じた [23] ように，不正機能検出も実務への適合が重要である．このため，各役割の実務者や経営層がどのように出力を読み，判断し，対応するかを対象にしたユーザスタディが有用であると考えられる．また，本調査で見られた依存関係更新時の確認や出力の優先度付けへの AI/LLM の利用について，有効性・限界と利用者による結果の検証可能性を実環境で評価することも有用であると推察される．

5.2.2 実務者への提言

まず，何れの役割においても，関係者間で不正機能の定義や検出対象の合意を形成することが重要である．設計・開発時には許可通信，保守機能，デバッグ機能，想定挙動を後工程で参照できる形で記録することが有用である．開発や運用では，現状の各種ツールによる恒常的な検査に不正機能，特に狭義の不正機能に係る自動調査を組み込むと共に，候補検出時の対応や役割間の引継ぎを定めることが望ましい．対応優先度は検出件数やツールによる重大度評価結果だけでなく，到達可能性，実利用，顧客環境，脅威動向，潜在的被害を組み合わせて総合的に判断すると共に，検出数等のツール依存の目標を避けることが重要である．ツールベンダやサービス提供者には，共通の検出結果から対象の役割に応じた説明を生成でき，既存のチケット管理，資産管理，SBOM，CI/CD 等へ段階的に連携可能な設計が求められる．加えて，機密性に応じた導入形態を選択可能とし，検出ルール，脆弱性・悪性パッケージ情報，規制・報告形式を継続的に更新することが望ましい．

6. おわりに

本研究では，複数の役割に跨る 17 名へのインタビューを基に，不正機能検出に係る実態，課題，および実践的支援のための要件を導出・整理した．本研究の結果が，今後の不正機能検出に関する研究，ツール開発，および実務改善の一助となれば幸いである．

謝辞 本研究の一部は，JST「経済安全保障重要技術育成プログラム」（JPMJKP24K2）によるものである．

参考文献

[1] Kanei, F. et al.: Analyzing the Use of Public and In-house Secure Development Guidelines in U.S. and Japanese Industries, *CHI*, pp. 1–17 (2023).
[2] Kalu, K. G. et al.: An Industry Interview Study of Software Signing for Supply Chain Security, *USENIX Security*, pp. 81–100 (2025).
[3] Torres-Arias, S. et al.: in-toto: Providing Farm-to-Table Guarantees for Bits and Bytes, *USENIX Security*, pp. 1393–1410 (2019).
[4] Huang, C. et al.: DONAPI: Malicious npm Packages Detector Using Behavior Sequence Knowledge Mapping, *USENIX Security*, pp. 3765–3782 (2024).
[5] Ladisa, P. et al.: SoK: Taxonomy of Attacks on Open-Source Software Supply Chains, *IEEE S&P*, pp. 1509–1526 (2023).
[6] Lasse Collin: XZ Utils backdoor. `https://tukaani.org/xz-backdoor/`.
[7] Downing, E. et al.: DeepReflect: Discovering Malicious Functionality through Binary Reconstruction, *USENIX Security*, pp. 3469–3486 (2021).
[8] EUR-Lex: Regulation - 2024/2847. `https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng`.
[9] NIST: Executive Order 14028. `https://www.nist.gov/itl/executive-order-14028-improving-nations-cybersecurity`.
[10] Charmaz, K.: *Constructing Grounded Theory*, SAGE, 2nd edition (2014).
[11] Zimmermann, M. et al.: Small World with High Risks: A Study of Security Threats in the npm Ecosystem, *USENIX Security*, pp. 995–1010 (2019).
[12] Williams, L. et al.: Establishing a Baseline of Software Supply Chain Security Task Adoption by Software Organizations, *SCORED* (2025).
[13] Sammak, R. et al.: Developers' Approaches to Software Supply Chain Security: An Interview Study, *SCORED*, pp. 56–66 (2024).
[14] Ganz, T. et al.: Detecting Backdoors in Collaboration Graphs of Software Repositories, *CODASPY*, pp. 189–200 (2023).
[15] Kokkonis, D. et al.: ROSA: Finding Backdoors with Fuzzing, *ICSE*, pp. 2816–2828 (2025).
[16] NIST: SP 800-161 Rev. 1: Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, Technical report, NIST (2024).
[17] Mansouri, M. et al.: Eliminating Vulnerabilities by Disabling Unwanted Functionality in Binary Programs, *ASIA CCS*, pp. 259–273 (2023).
[18] Azad, B. A. et al.: Less is More: Quantifying the Security Benefits of Debloating Web Applications, *USENIX Security*, pp. 1697–1714 (2019).
[19] Alahmadi, B. A. et al.: 99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms, *USENIX Security*, pp. 2783–2800 (2022).
[20] Kloeg, B. et al.: Charting the Path to SBOM Adoption: A Business Stakeholder-Centric Approach, *ASIA CCS*, pp. 1770–1783 (2024).
[21] McDonald, N. et al.: Reliability and Inter-rater Reliability in Qualitative Research: Norms and Guidelines for CSCW and HCI Practice, *PACM HCI (CSCW)*, pp. 1–23 (2019).
[22] Lazar, J. et al.: Research Methods in Human Computer Interaction. Morgan Kaufmann (2017).
[23] Kaur, H. et al.: "Threat modeling is very formal, it's very technical, and also very hard to do correctly": Investigating Threat Modeling Practices in Open-Source Software Projects, *USENIX Security*, pp. 2125–2144 (2025).
[24] Vassallo, C. et al.: Context Is King: The Developer Perspective on the Usage of Static Analysis Tools, *SANER*, pp. 38–49 (2018).
[25] Dittrich, D. et al.: The Menlo Report: Ethical Principles Guiding Information and Communication Technology Research, Technical report, U.S. DHS (2012).

© 2026 Information Processing Society of Japan

研究倫理

我々の組織には本研究分野に関する Institutional Review Board（IRB）が存在しないため，Menlo Report [25] や関連する先行研究を参照して本研究を設計した．参加者募集に際して，メールで研究目的と内容を説明し，希望者に対しては追加で約 30 分の事前説明会を実施した．インタビューは，事前に書面による同意を得たうえで，開始前に口頭でも同意を得られた場合にのみ実施した．インタビューの間，参加者は回答したくない質問をスキップでき，インタビュー後に回答の修正・撤回もできた．この結果，3.4 節で言及した通り，4 件の修正と 1 件のオプトアウトを実施した．また，個々の参加者が特定されないよう，本稿で用いるデータには仮名化を施した．

これらの個人情報の取り扱いや保護については，著者の所属組織が有する個人情報保護担当部門の監査を受け，承諾を得た．具体的には，録音，書き起こし，およびコード化データはアクセス制限下で管理し，元データは公開しない．さらに，同部門の監修の下でプライバシー影響評価（PIA：Privacy Impact Assessment）に係る検証を実施し，問題ないことを確認した．具体的には，取得したデータの保管方法，定期的な自己監査の周期と方法，およびアクセス制御の方法等の監査・リスク評価を受け，承諾を得た．

付　　録

A.1　略語一覧

表 A·1 に本稿で用いた主な略語を示す．

表 A·1　本稿で用いる主な略語

略語	意味
CI/CD	Continuous Integration/Continuous Delivery
CSAF	Common Security Advisory Framework
CSIRT	Computer Security Incident Response Team
DAST	Dynamic Application Security Testing
EDR	Endpoint Detection and Response
MSS	Managed Security Service
PSIRT	Product Security Incident Response Team
SBOM	Software Bill of Materials
SCA	Software Composition Analysis
SAST	Static Application Security Testing
SOC	Security Operations Center
VEX	Vulnerability Exploitability eXchange

A.2　インタビューおよびアンケート項目

透明性，再現性，およびオープンサイエンスの観点から，事前質問票，インタビューガイド，コードブックを本付録に示す．参加者と組織の機微情報を保護するため，録音と全文書き起こしは公開しない．この方針は参加者から得た同意内容と，所属組織の個人データ保護部門との調整に基づく．生データの代わりに，テーマ分析結果と匿名化した発言を本文で報告している．

A.2.1　事前質問票

インタビューに先立ち，以下のアンケートを通して参加者の属性情報を収集した．

- Q1. 不正機能検出に係る職務について教えてください．複数の職務経験がある場合は全てお答えください．
- Q2. 上記職務の経験年数を教えてください．複数の職務経験がある場合はそれぞれについてお答えください．
- Q3. 上記の職務以外も含むセキュリティ業務への総従事歴を教えてください．

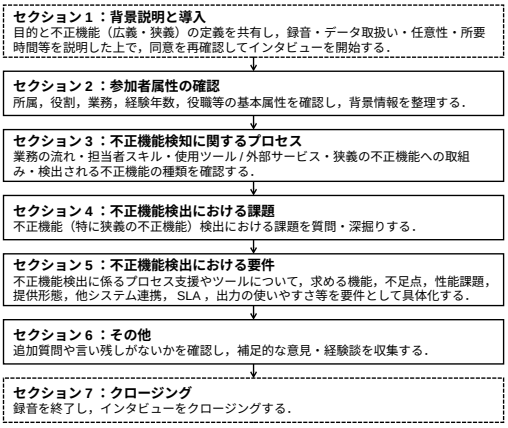


図 A·1　半構造化インタビューの流れ

- ご協力ありがとうございました．ご不明点等がございましたら，[第一著者名（メール）] までご連絡ください．ヒアリング当日もどうぞよろしくお願いいたします．

A.2.2　インタビューガイド

図 A·1 に，インタビューの流れを示す．先行研究 [20] 等を参考に，各参加者の役割に合わせて質問内容を調整した．**DES** は設計者，**DEV** は開発者，**OPE** は運用担当者，**TV** はツールベンダ，**SP** はサービス提供者を表す．役割別の質問には対応する略称を記載しており，記載のないものはすべての参加者に質問した内容である．

セクション 1：背景説明と導入

- インタビューに貴重な時間を割いていただき，ありがとうございました．準備はよろしいでしょうか．
- まず最初に，インタビューの要旨とデータの取り扱いについてお話しし，すべてに同意していただけましたら，実際のインタビューに入ります．
- 本日は，ソフトウェアの不正機能検出に関しまして，実務でのご経験に基づいて，ご意見を頂きたいと考えております．どうぞよろしくお願いいたします．
- 大きく 3 つ，これまでに実施された不正機能検出の取組について，それらの取組を行うにあたっての課題について，不正機能検出を支援するツールに求められる要件についてお伺いできればと考えております．
- 不正機能の定義ですが，不正機能には，(i) 広義の不正

© 2026 Information Processing Society of Japan

機能と (ii) 狭義の不正機能があり，狭義の不正機能は悪意のある第三者が意図的に組み込むものと定義しています．一般的に，不正機能検出は広く (i) を対象として取り組まれていると想像しておりますが，特に (ii) について実施している取組やご意見があればお聞かせ頂きたいと思います．

- 次に，告知事項について説明させてください．まず直近では，これまでに他の方に実施させていただいたインタビューや本日のインタビューの内容とその分析結果をまとめてフィードバックさせていただくという形で貢献できればと考えています．また，将来的には報告書や論文等としてもまとめていく予定です．
- 本インタビューにおける回答はすべて任意であり，分からない質問や答えたくない質問があれば一部またはすべて回答をスキップしていただくことも可能です．
- インタビューの所要時間は，回答時間にもよりますが，これまでの経験では 45〜90 分程度です．このインタビューは録音させていただきます．
- 録音は，個人情報管理委員会の監査の下管理し，5 年の保管期間の後破棄されます．
- 以上の内容について同意いただいた場合，インタビューに進ませていただきます．インタビュー，データの取り扱い，記録等についてご質問がありますでしょうか．
- 既に同意書は書いていただきましたが，改めて確認させてください．インタビューの実施に同意いただけますでしょうか．
- （同意時）それではここから録音を開始します．

セクション 2：参加者属性の確認

- ［参加者］さまは，［参加者の組織］に所属されており，［参加者の業務］に従事されていると伺っております．
- 具体的な業務と，ご経験年数を教えてください．
- 業務での役割・役職についても教えてください．
- これまでにご担当されたお客様は，どのようなドメインのお客様でしたでしょうか．
- 申告された業務に限らず，セキュリティ関連の業務とご経験年数についても教えていただけますでしょうか．

セクション 3：不正機能検出に関する実態

- ［役割］に関する業務について，ワークフロー，作業の順序，必要なスキルを教えていただけますでしょうか．また，狭義の不正機能の検出を特に目的とした取組があれば，あわせて教えてください．
- ［役割］の業務で利用するツールや外部サービスについて教えていただけますでしょうか．また，狭義の不正機能を検出することを意図した手法やツールがあれば，あわせて教えてください．
- ［役割］の業務では，どのような不正機能を検出されていますか．

セクション 4：不正機能検出における課題

- ［役割］の業務で不正機能を検出する際，主な課題は何でしょうか．
- また，その課題はどの作業で生じますか．
- 狭義の不正機能に特有の課題はありますか．

セクション 5：不正機能検出における要件

- ［役割］の業務を改善するため，不正機能検出機能を持つツールにはどのような機能が必要でしょうか．
- 現在そのようなツールを使っている場合，どのような機能上の限界を観察されましたか．使っていない場合は，どのような限界が予想されますか．
- 現在そのようなツールを使っている場合，どのような性能上の問題を観察されましたか．使っていない場合は，どのような問題が予想されますか．
- 不正機能検出ツールには，どのような提供形態が望ましいでしょうか．また，その理由は何でしょうか．
- そのようなツールは，他のシステムと統合されるべきでしょうか．望ましい統合方法があれば教えてください．
- **OPE，TV，SP：**可能であれば，脆弱性またはインシデント報告を受けてから脅威分析を完了するまでの時間など，［役割］の業務における応答時間目標や SLA について教えていただけますでしょうか．
- **DES，DEV，OPE，TV：**ご経験またはご想定に基づき，そのようなツールの利用や出力の解釈に関して，どのようなユーザビリティ上の課題があるか教えていただけますでしょうか．
- 現在のツールや手法では，どのような脆弱性が見逃されやすい，または誤検出されやすいでしょうか．また，見逃しと誤検出の主な原因は何でしょうか．

セクション 6：その他

- 用意させていただいた質問は以上です．他の参加者からの質問はありますでしょうか．
- インタビュー中に取り上げなかったことで，不正機能検出に関して何かお話していただける内容はありますでしょうか．

セクション 7：終了

- それではここで録音を終了します．
- ここからは録音していないため残りませんが，改めて何か話したいことはありますでしょうか．
- 本日は貴重なお時間を割いていただき，また貴重なお話をお聞かせいただき，改めてありがとうございました．

A.2.3 コードブック

表 A·2 に，人口統計等の補助コードを除く，分析へ用いた主要コードを示す．

© 2026 Information Processing Society of Japan

表 A·2 コードブック（1/3）

上位コード/下位コード	コード内容
1. 不正機能検出の形態	
広義の対象・脆弱性管理	実行時エラー，バッファオーバフロー等の一般脆弱性，既知脆弱性，廃止 API・システムコール，コーディング規約違反，高負荷時障害，例外処理不備，不要アカウント，弱い暗号，アクセス制御不備，インジェクション，平文等の不安全な資格情報保存，不適切なセッション期限，未サポート・EOL ソフトウェア，不正アクセス，脆弱性スキャン通信.
狭義として明示された対象	バックドア・保守用バックドアアカウント，ハードコード資格情報，Web カメラ映像等の秘密裏の外部送信，仕様外コード，不審宛先への通信，悪性パッケージ，未許可の外部ファイル転送，脆弱性検査と異なる分析を要する意図的挿入，IoT・AI チャットボットの不正機能，ソースパターン照合，悪性ライブラリ注入のバイナリ照合，不審通信のパケット検査.
二層運用・境界事例	意図帰属を行わない広義検出，狭義を対象外とする運用，広義と狭義でルールを分離する運用，両者の同時実行.
2. 不正機能検出に係る役割・工程別の実施事項	
設計段階	シミュレータによる異常入力処理の検証，設計セキュリティ評価，脅威モデリング.
開発段階	OSS 脆弱性管理，PoC・攻撃コード確認，SCA によるコンポーネント管理，規約違反検出，TrustZone による機密データ保護，セキュアブート・安全なメモリ利用支援，SAST，動的試験，リンタ，チェックリスト，CI/CD への不正機能検出統合.
リリース前・第三者検証	脆弱性試験，ソースコードレビュー，プライバシー問題検出，ライセンス確認，コンポーネント一覧・SBOM 作成，既知脆弱性照合，実行時エラー，ペネトレーションテスト，ファジング，性質ベース・単体試験，出荷時のデバッグアクセス無効化，脆弱性トリアージ，バイナリ解析，分析の多様性を保つため手順を固定しない運用.
運用・更新時の継続検証	セキュリティ監視，脆弱性管理，EOL 検出，依存関係更新時の生成 AI による不審変更確認，最新版を直ちに適用せず段階的に確認する運用.
検出後のトリアージ・優先度付け	利用有無・未実行でも発火可能かの確認，KEV，PoC，SSVC，EPSS，到達可能性，被害規模，ツール重大度，実務経験を用いた優先順位付け.
顧客・開発・PSIRT・利用者の役割	PSIRT による修正依頼だけでない方針・実装調整，検出可能範囲の事前合意，顧客の脆弱性優先度要求，開発・品質保証・営業等で異なる目的，高成熟度顧客による内製運用.
3. 多層的な検出手法とツールの組合せ	
静的・コード・ルール解析	デバッガを用いる静的解析，CWE・脆弱性対応のソース解析，Semgrep，Go 静的解析器，GitHub Code Scanning.
動的解析・ファジング・攻撃シミュレーション	ファジング，ペネトレーションテスト，未知ツールのオフライン・サンドボックス実行，動的セキュリティ試験，到達可能性確認，Radamsa，Metasploit，OpenBAS，Vex，対象応答に応じる適応的ファジング.
バイナリ・リバース・ファームウェア解析	逆アセンブラによる静的解析，ファームウェア・ファイルシステム抽出，秘密鍵等のハードコード情報，不要サービス，CWE 対応脆弱性のバイナリ検出，Ghidra，Binary Ninja，IDA.
SCA/SBOM・脆弱性 DB 照合	悪性パッケージ検出，既知脆弱性一覧化，コンポーネントと DB の照合，OWASP ZAP，Dependabot，Syft，Trivy，OpenSSF 悪性パッケージ情報.
通信・ログ・運用基盤	異常時の機器挙動監視とログ解析，Wireshark，Nmap，中間者プロキシ.
AI/LLM・内製支援	依存ライブラリ更新時の生成 AI 確認，市販・OSS ツールの不足を補う内製，LLM によるツール出力の優先度付け.
4. 検証の実施要因	
規制・調達・政府・市場・経営による需要	過去 4–5 年の IoT・AI 製品に関する依頼増加，バックドア報道と経営懸念，第三者検証，車載・Bluetooth 等の安全影響，JIS T 81001-5-1，CRA，医療・薬事，経済安全保障推進法，納入時証拠，JC-STAR，医療・EU・金融向け新サービス検討.

© 2026 Information Processing Society of Japan

表 A·3　コードブック（2/3，続き）

上位コード/下位コード	コード内容
5．検出対象・判断基準・結果解釈の不確実性	
狭義の定義・目的の曖昧さ	脆弱性試験より曖昧な目的・対象，少ない先例，存在有無が不明な対象の停止条件，共通定義・検出方法の欠如，ゼロから悪性コードを探す難しさ，検出知識不足，事業上の非開示による困難.
意図・真正性・仕様適合の判断	修正による機能変更，スレッド非安全・アクセス制御欠落が意図的かの判断，大量調達後の正式問題化に必要な証拠，結果妥当性と内外調整，専門性依存の真正性・優先度，停止が欠陥か意図動作かの区別，重大見逃しを避けつつ検出ゼロを望む開発側，非公開・不正確な仕様.
トリアージ・情報過多・目的逸脱	優先度付けのベストプラクティス欠如，根拠の弱い評価尺度，CVE 優先だけでは不足，CVSS 8/9 閾値への疑問，顧客環境文脈不足，CVSS だけで絞れない大量結果，版照合による数千件の候補，検出件数の目的化.
サプライチェーン固有の悪意・回避	外部組織を統制できず意図的挿入を検出しにくいこと，内部者が検出器を解析し回避する可能性，ツール自体の保護.
検査範囲・停止条件	検査を際限なく続けられること，試験不足で残る機能欠陥，セキュリティ・バイ・デザインで防げた欠陥をどこまで含めるか.
6．検出精度と解析上の技術的限界	
精度・見逃し・誤検出	100%でない精度と最終レビュー，到達可能性粒度による誤検出，見逃しを抑えるための広い検出，SBOM 照合精度，無効化・入力制限済み機能，ゼロデイ非対応，環境・脅威文脈を無視した重大度，出荷時に除去されたドライバの誤検出.
静的・動的・バイナリ固有の限界	ファジング再現性，動的リンクを含む動作再現，デコンパイル可読性，ソースより低いバイナリ解析精度，異常入力の特定，エラー定義，ヒープ脆弱性，深いネスト・関数ポインタ，状態依存，ファジング方式によるカバレッジ差，strip 済みバイナリの同定精度.
設計・横断挙動・言語意味論	設計レベル脆弱性，複数関数にまたがる条件，C/C++等の未定義動作.
7．規模，環境，データ品質，統合に伴う運用上の制約	
規模・実行時間・資源	大規模対象で数日かかる静的解析，手動リバース，大量ファジングログ，深い検査，多数機器・脆弱性，非並列化，グローバル変数，メモリ・ディスク，夜間バッチ化，CI/CD・リアルタイム統合阻害，費用・性能・品質のトレードオフ，分割解析.
対象環境・ハードウェア・言語・アクセス	アプリ固有ファジング，入手困難な外部ハード，バイナリのみの納品，未対応言語，顧客別の侵入経路設計，試験・本番環境差，通信性能による制限，上位アプリ試験の仕様依存，取得可能情報の制約.
データ品質・標準・エコシステム未成熟	SBOM 未提供，名称揺れ，SCA 出力品質差，CVE 採番前の対応，NVD・JVN 等の DB 分散，記述粒度・CVSS 差，暗黙パッチ，資産管理不足，統一辞書欠如，規約未標準化，ツールごとの検出範囲差，比較データセット不足，バイナリ製品の SBOM 不足，曖昧な修正説明，SCA 品質保証と CRA・製造物責任対応に足る情報.
ツール統合・調整運用	分散したツールと異なる重要度尺度，多数の調整パラメータ，複数ツール統合の難しさ，標準出力形式不足と手作業.
8．組織，ビジネス，規制，市場成熟度に起因する制約	
専門性・属人性	解析に必要な専門知識，人材不足，専門家が常に出力を確認できず，検証せず開発者へ転送する可能性.
予算・期間・契約・採算	予算・納期による範囲制限，人件費と採算，契約上できない根本原因助言，ライセンス・料金，検出後更新の工数・可用性・正常性バイアス，高価な IDA，顧客予算で決まる停止条件，改修困難なレガシーコード，大量調達後に見つかった候補.
組織文化・役割・顧客準備	組織文化ごとに異なる修正方法，規模・構造による制約，機能問題時のセキュリティ後回し，手作業中心の管理，顧客の対応能力・権限で変わる開示，重要インフラでの負荷懸念，検出件数偏重 KPI，顧客理解・協力の不足.
法令・ガイドライン解釈と費用	法令・ガイドラインの曖昧さによる実施内容・深度の不明確さ，ツール出力の対応不足，遵守費用.
市場成熟度・顧客認知・教育	他領域より低い認知と導入合意の難しさ，国内ツール不足，利用者のリスク理解不足による見逃し，脆弱性・狭義検出の理解不足，未成熟市場，完全検出への期待，SBOM・脆弱性管理の未成熟，詳細説明を望まない運用者.

© 2026 Information Processing Society of Japan

表 A·4　コードブック（3/3，続き）

上位コード/下位コード	コード内容
9．検出対象と検出性能の要件	
対象定義・検出範囲	対象となる不正機能の明確化，明確な定義に基づく検出，既知脆弱性一覧，多様な言語・アーキテクチャ・独自ビルド規則・プロトコルへの対応.
精度・調整・再現性	高精度，調整可能なパラメータ，ペイロード・プロトコル等のカスタマイズ，ある程度の誤検出を許容して見逃しを抑制，独自プロトコル試験生成，動的試験の再現，SBOM 依存関係の詳細検出.
攻撃シミュレーション・仕様生成・非コード手法	ファジング，攻撃コード生成，実行をまたぐ攻撃フロー再現，バイナリからの仕様生成，署名・検証等の非ソース／非バイナリ手法.
10．説明可能性，証拠，意思決定支援の要件	
リスク・優先度情報	候補検出後の分類・トリアージ，優先度による並べ替え，顧客環境別のリスクと優先度，複数候補の優先付け，CPE，ベンダ名，実行ファイルハッシュ，流行度等の根拠.
組織横断管理支援	結果管理，組織全体のリスク管理フローへの適合，対応状況，製品所有者・経営向け可視化，他組織との対応比較，組織全体での評価・管理.
調査手順・修正案・検出根拠	検出後分析・対応の提案と支援，対応要否と方法，過去の誤検出抑制等の判断反映，何を調査しどう検証するか，高コスト分析の支援，検出理由，コード位置，根拠・ロジック，ファジングの標準化，エラー出力と原因分析.
UI・可視化・出力・非専門家説明	PDF と対象の照合負担，機能単位説明，可視化・一覧，ドラッグ&ドロップ，ソース強調，周辺コード，解析失敗時エラー，進捗，編集可能な CSV・YAML，試験内容・カバレッジ，非専門家向け影響説明，単純 UI で詳細へ到達しにくい問題，追跡困難な詳細ログ，運用者向け対応・優先度・リスク，日本語出力.
11．継続的検証，自動化，ワークフロー統合の要件	
高頻度・継続検証，CI/CD，自動化	年次より高頻度の検出，API 誤用・引数エラーのリアルタイム表示，リリース時だけでない運用中検出，任意時点での CI/CD 実行，属人性低減，悪性コミットの阻止，省力化，新規脆弱性時の自動試験，可用性へ影響しない継続診断.
ツール・システム・API・SBOM・チケット統合	複数ツール同時適用，ツール間連携，静的・動的解析の一連化，横断ダッシュボード，環境間結果統合，SBOM 統合，社内ハブ共有，GitHub・CI/CD，過去修正の知識基盤，チケット，任意連携用 Web API，SSO，第三者 SBOM と資産 DB，統合不要という要望，手動・自動結果統合，AI 等への API 出力，既存環境への後付け容易性.
12．導入形態，データ保護，サービス運用の要件	
クラウド・オンプレミス・SaaS・データ保護	オンプレミス，クラウド，両対応，OT・重要インフラの機密データアップロード懸念，オンプレミスの規模制約，SaaS の利便性と機密性要求，オンプレミス製品のリバース・盗難リスク，ビルド挙動・ハード情報がない SaaS の限界，国内外で異なるクラウド許容度，クラウド中心開発による高精度化.
SLA/SLO・ライセンス・費用・運用	分かりやすいライセンス，分析報告日数，脆弱性管理・検出性能の SLA 未設定，将来の SLO/SLA，復旧時間，発見から報告までの日数，価格による試験時期の制約，バッチ用途では 24 時間稼働が必須でないこと，有料ツールの高価格，サービス稼働率，費用負担.
13．知識更新，規制対応，教育支援の要件	
利用者理解・教育・LLM 利用可能な知識	不正機能への理解を促す機能，非専門開発者向けの平易な出力・補足，専門家以外にも広がる検出を法令適合証拠として使える説明，VEX・CSAF・CVRF 等の開示形式，人と LLM の双方が利用しやすい出力.
DB・ルール・規制変更の継続更新	検証 DB・知識ベースの最新化，日々の脆弱性更新追跡，暗黙パッチ対応，新解析器を追加しやすい構成，特に欧州の新規制に応じた機能追加.

© 2026 Information Processing Society of Japan